PostFinance

DIE POST

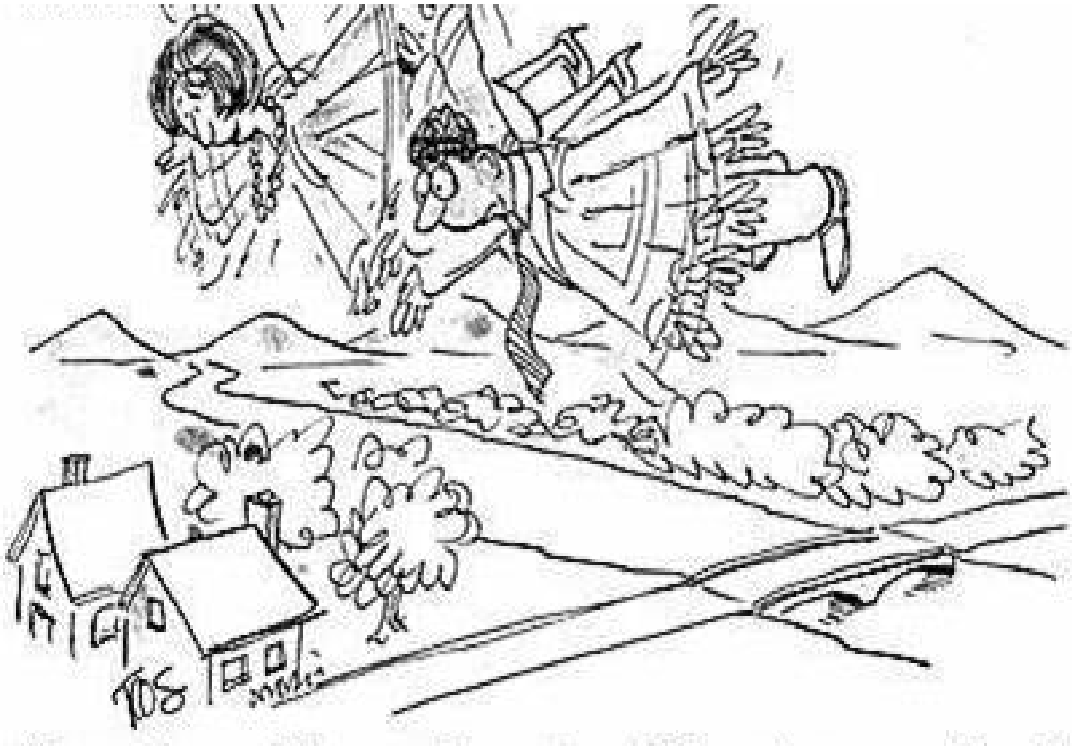
Branchenkonforme IT-Sicherheit

Markus Siffert - Sicherheitsbeauftragter Informatik

Klassifikation: öffentlich

Zielsetzungen
Leitgedanken

To manage company-wide risk and compliance you must be able to see through walls, around corners, and thousands of miles away. Impossible? It depends on how you look at it (ca).



Agenda

- Einleitung
- Ausgangslage
- Lösungsansatz
  - Compliance Strategie / Cartography
  - Risk und Policy Management
  - Risk Control Self Assessment
  - Key Risk Monitoring
- Fragen / Diskussion

Agenda

- Einleitung
- Ausgangslage
- Lösungsansatz
  - Compliance Strategie / Cartography
  - Risk und Policy Management
  - Risk Control Self Assessment
  - Key Risk Monitoring
- Fragen / Diskussion

Die Lösungen

100 Applikationen für mehr als 70 Marktangebote

PostFinance DIE POST Besser begleitet.

de | fr | it | en | Home | Die Post | Kontakt | Sitemap |

Privatkunden | Gesch

Produkte | Angebote | Kundendienst | E-Finance

Home › Geschäftskunden › Produkte

- Direkt beantragen
- Aktuelle Zinssätze
- Konten
- Karten
- Zahlungsverkehr
- Anlegen
- Finanzieren
- E-Services
- Infos und Tipps

Produkte

Direkt beantragen
- Produkte und Dienstleistungen direkt beziehen

Aktuelle Zinssätze

Konten
- Für Zahlungsverkehr und Cash Management: Geschäftskonto und (E-)Depositokonto

Zahlungsverkehr
- Umfassende und individuelle Lösungen für den Zahlungsverkehr im In- und Ausland

Anlegen
- Professionelles Cash m… gewinnoptimierten Anlagestrategien

Finanzieren
- Individuelle Finanzierungsmodelle für Ihre Liquidität

E-Services
- Leistungsstarke elektronische Lösungen für alle Geldgeschäfte

E-Finance

PostFinance DIE POST Besser begleitet.

de | fr | it | en | Home | Die Post | Kontakt | Sitemap |

Privatkunden | Gesch

Produkte | Angebote | Kundendienst | E-Finance

Home › Geschäftskunden › Produkte › Konten

pf.ch

- Direkt beantragen
- Aktuelle Zinssätze
- › Konten
  - Produktvergleich
  - Geschäftskonto in CHF
  - Geschäftskonto in EUR
  - Geschäftskonto in Fremdwährungen
  - Depositokonto für Unternehmen
  - E-Depositokonto für Unternehmen
  - Vereinskonto
  - Depositokonto für Vereine
  - E-Depositokonto für Vereine
- Karten
- Zahlungsverkehr
- Anlegen
- Finanzieren
- E-Services
- Infos und Tipps

Konten

Produktvergleich
- Welches Konto kann was?

Geschäftskonto in CHF
- Das Basiskonto für Unternehmen
- Zahlungsverkehr einfach und effizient
- Kontoführung übers Internet, Datentransfer und Telefon

Geschäftskonto in EUR
- EUR-Zahlungsverkehr im In- und Ausland
- Einzahlungsscheine und Debit Direct in EUR
- Weltweiter Bargeldbezug in EUR

Geschäftskonto in Fremdwährungen
- Kontoführung in einer von 8 Währungen
- Für den weltweiten Zahlungsverkehr
- Mit der Sicherheit des Schweizer Finanzplatzes

Depositokonto für Unternehmen
- Flexibles Anlagekonto
- Kostenlose Kontoführung in CHF oder EUR

E-Depositokonto für Unternehmen
- Das Anlagekonto übers Internet führen
- Kostenlose Kontoführung in CHF oder EUR
- Erstklassiger Zinssatz

Vereinskonto
- Das Konto für jeden Vereinszweck
- Kontoführung in CHF oder EUR
- Online-Zugriff via E-Finance

Depositokonto für Vereine
- Flexibles Anlagekonto
- Kostenlose Kontoführung in CHF oder EUR
- Auf Wunsch mit Karte für Bargeldbezug

E-Depositokonto für Vereine
- Das Anlagekonto übers Internet führen
- Kostenlose Kontoführung in CHF oder EUR
- Erstklassiger Zinssatz

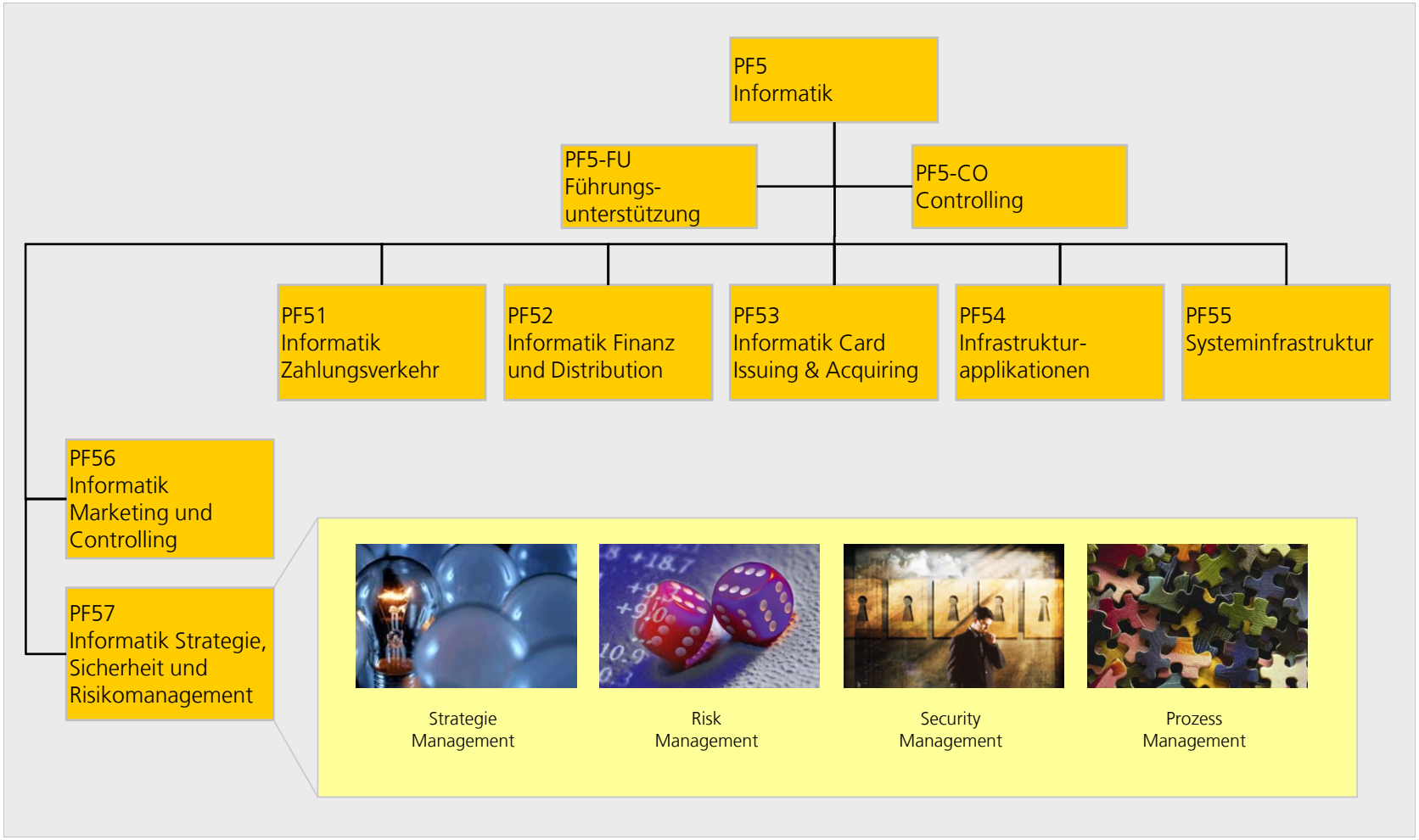
ZV

Die Technologie

Über 850 Server, über 300km Kabel

Die Organisation

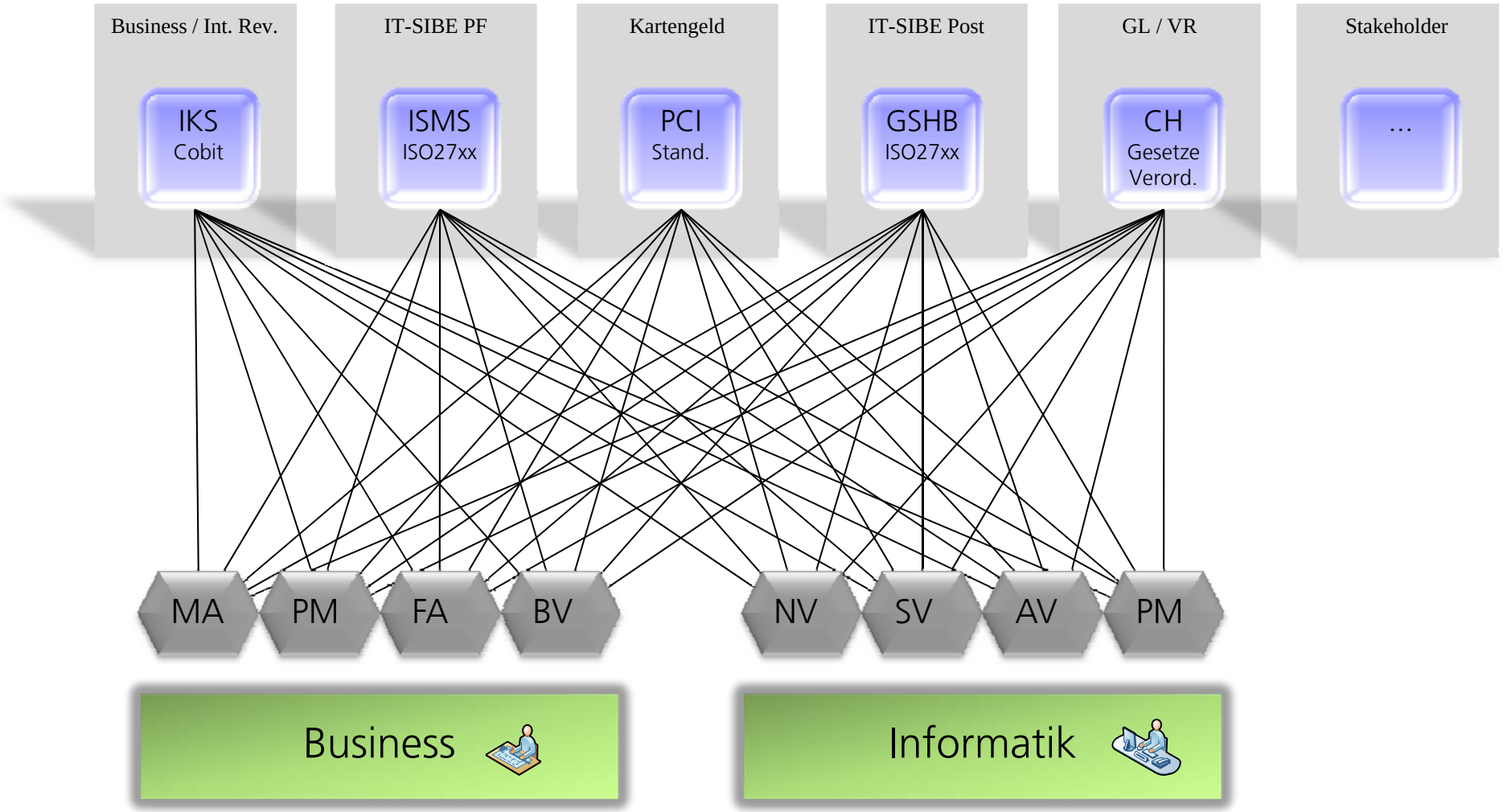
Entwicklung, Test und Betrieb aus einer Hand



Agenda

- Einleitung
- Ausgangslage
- Lösungsansatz
  - Compliance Strategie / Cartography
  - Risk und Policy Management
  - Risk Control Self Assessment
  - Key Risk Monitoring
- Fragen / Diskussion

Ausgangslage (1/2)
Herausforderungen



Ausgangslage (2/2)
Herausforderungen

- Organisatorische Silos
  - Die organisatorischen Silos besitzen unterschiedliche Sichten auf teilweise identische Schwachstellen und Risiken.
- Duplizieren von Informationen
  - Wichtige Controls werden mehrfach in unterschiedlichen Compliance Programmen getestet (Keypersonen sind zusätzlich belastet).
- Redundante Aktivitäten in Silos
  - Programm-Silos starten selbständig Vorhaben zur Beseitigung der Schwachstellen. Oft adressieren unterschiedliche Compliance Programme identische Vorhaben.

➡ Ineffektivität und Ineffizienz, hohe Kosten und geringe Produktivität

Agenda

- Einleitung
- Ausgangslage
- Lösungsansatz
  - Compliance Strategie / Cartography
  - Risk und Policy Management
  - Risk Control Self Assessment
  - Key Risk Monitoring
- Fragen / Diskussion

Chancen und Lösungsansatz (1/3)

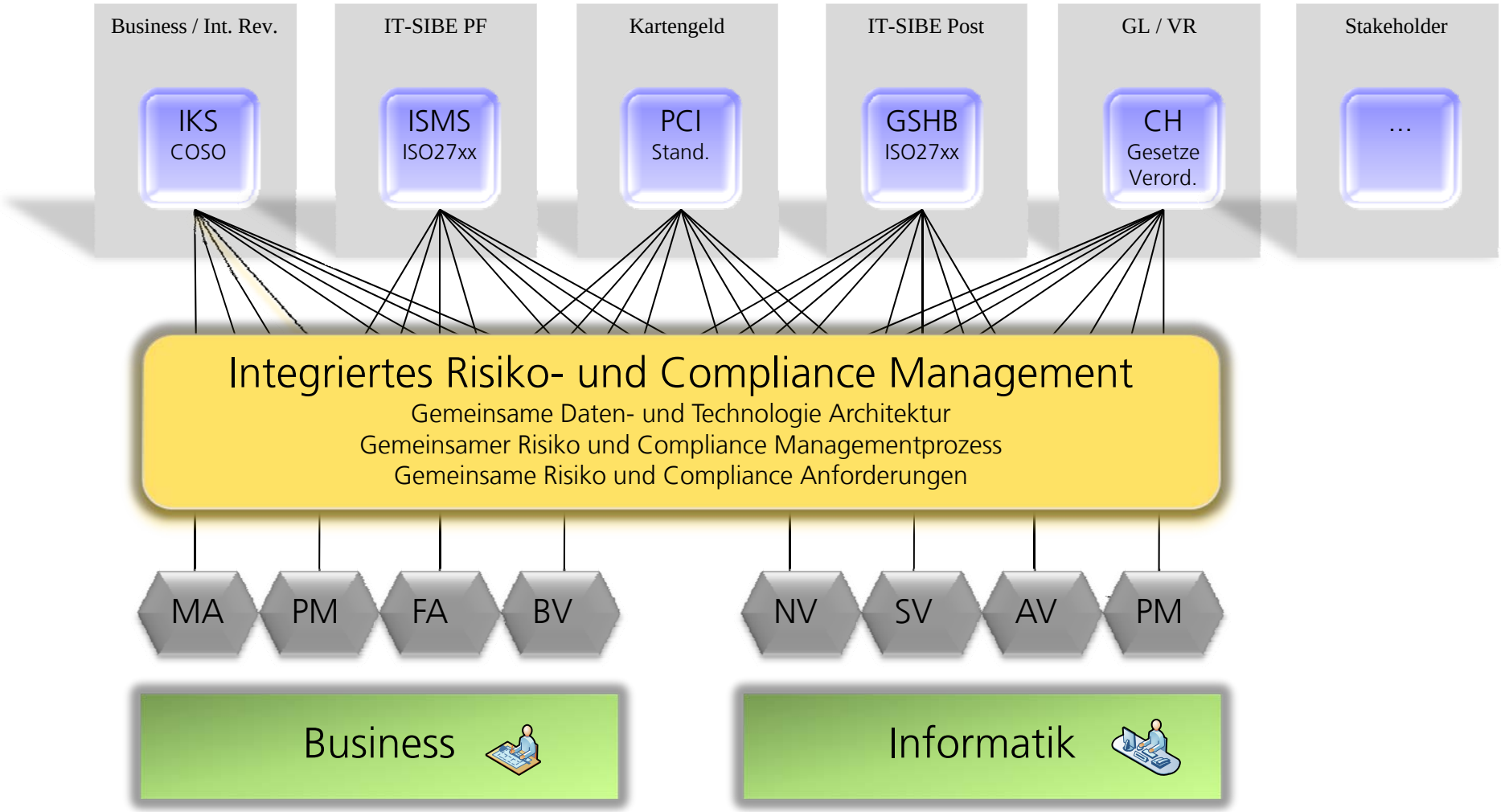
Wichtige Elemente

- Zentrales Programm Management
  - Initiierung, Planung und Umsetzung mit Management Attention.
- Zentralisiert und verwaltbar
  - Ein Repository für alle relevanten Vorgaben, Risiken und Compliance Programme.
- Integriertes Risk Management
  - Integriertes Risk Management inkl. geeigneter Key Risk Indikatoren.
- Reporting - Key Risk Indikatoren
  - Einfache Darstellung für unterschiedliche organisatorische Silos in Dashboard.

➡ Integriertes Risiko- und Compliance Management

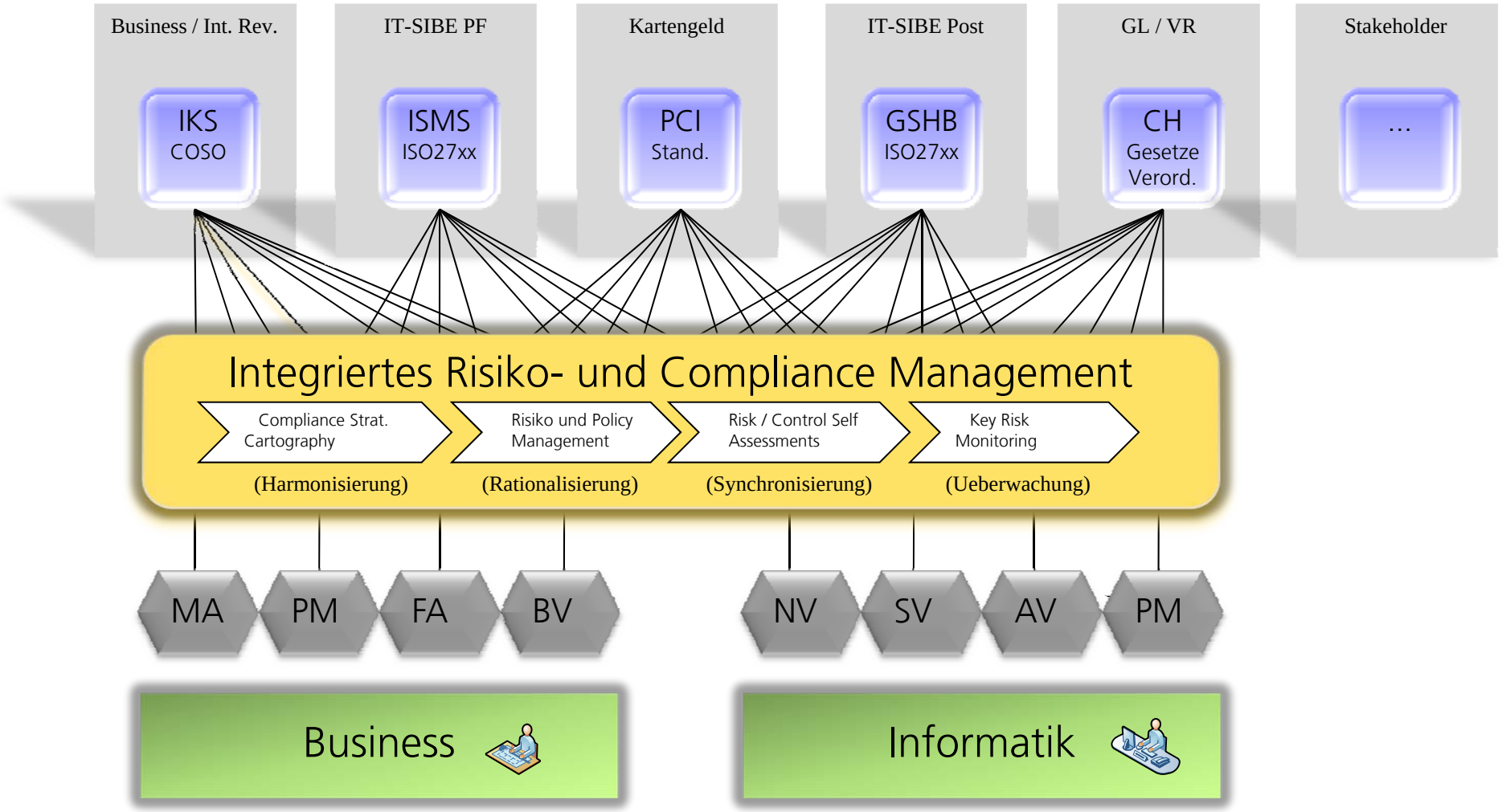
Chance und Lösungsansatz (2/3)

Zentrales Programm Management



Chancen und Lösungsansatz (3/3)

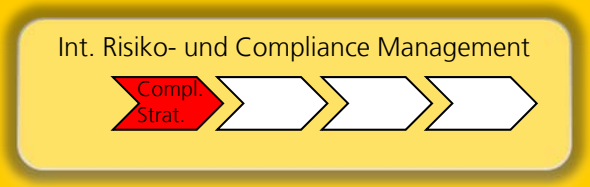
Methodik



Agenda

- Einleitung
- Ausgangslage
- Lösungsansatz
  - Compliance Strategie / Cartography
  - Risk und Policy Management
  - Risk Control Self Assessment
  - Key Risk Monitoring
- Fragen / Diskussion

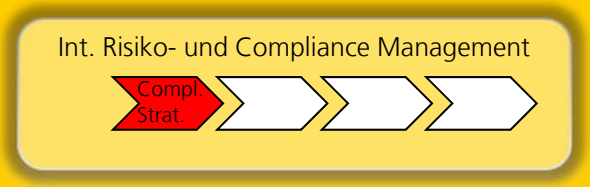
Compliance Strategie (1/2)
Konzeption



- Allgemeines
  - Owner: Informatik Strategie, Sicherheit und Risikomanagement
  - Beteiligte: Sicherheit, Prozessmanagement, Riskmanagement, IKS, Revision, Linie
- Strategie
  - Welche Vorgaben gelten für uns als PostFinance?
  - Welche Vorgaben wirken auf was (Informationen, Applikationen, Prozesse, etc.)
  - Ergebnis: Compliance Strategie -> Compliance Cartography
- Taktik
  - Wie werden wir compliant und wie setzen wir Revisionen, Audits, Zertifizierungen, Self-Assessments ein? Verantwortlichkeiten, Zyklus, etc.?
  - Ergebnis: Compliance Strategie -> Methodik

Compliance Strategie (2/2)

Umsetzung



- Koordination Ist-Aufnahme
  - Planung, Abstimmung mit allen Stakeholdern
  - Durchführen Ist-Aufnahme (Self-Assessment)
  - Ergebnis: Schwachstellenanalyse

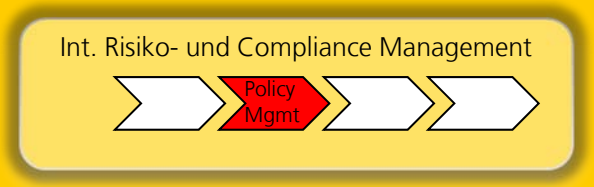
- Koordination Massnahmen Umsetzung
  - Planung, Abstimmung mit allen Stakeholdern
  - Kosten (Effektivität / Effizienz)
  - Ergebnis: Reporting - Dashbord

Agenda

- Einleitung
- Ausgangslage
- Lösungsansatz
  - Compliance Strategie / Cartography
  - Risk und Policy Management
  - Risk Control Self Assessment
  - Key Risk Monitoring
- Fragen / Diskussion

Risk und Policy Management (1/4)

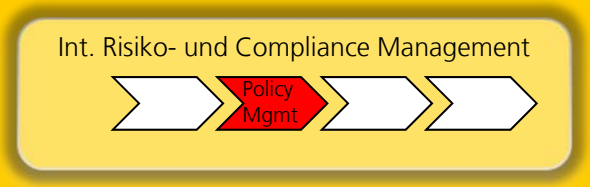
Welche Vorgaben wirken auf was?



Banken-Gesetze	Referenz	Risiko Auswirkung	Risiko Skalierung	Geltungsbereich	ISO 20000-1/-2	ISO 27001	COBIT-Framework 4.0
Nationalbank-Gesetz: Art. 47		Reputationsrisiko Sorgfaltspflichtrisiko	kritisch	Gesamte Bank	nicht spezifiziert für das Information Prozess Management	nicht spezifiziert für das Information Prozess Management	nicht spezifiziert für das Information Prozess Management
OR Art. 957ff, OR 962ff, OR 963	GeBüV, EIDI-V	Sorgfaltsrisiko Reputationsrisiko	kritisch	Compliance und Rechts-abteilung; Datenverarbeitung; Archivierungsabteilung; Interne Revision	Kap. 6.6.7	Kap. 4.3.2 Kap. 4.3.3 A.10.5.1	Monitor und Evaluation ME1 ME3 ME4
Bundesgesetz über den Datenschutz, DSG Art. 5 Richtigkeit der Daten Art. 7 Datensicherheit Art.11/11a Zertifizierungsverfahren / Registrierung der Datensammlung	Für die Umsetz-ung des Datenschutzes ist eine eigenständige Verordung beim Bund in Ausarbeitung.	Sorgfaltsrisiko Reputationsrisiko Integritätsrisiko Datenverlust Risiko	kritisch	Compliance- und Sicherheitsabteilung; Datenschutzbeauftragter; Personalabteilung; IT Betriebsmanagement; Daten-Owner (Dateneigner).	Applikations und Prozess spezifische Kontrollen Kap. 6.3 Kap. 6.3.2	Applikations und Prozess spezifische Kontrollen A. 6.2 A. 7.2 A.10.5 A.11 spezifisch A.11.1 bis A.11.7 A.15.1 und A.15.2	

Risk und Policy Management (2/4)

Welche Vorgaben wirken auf was (Prozesse)?



IT-Governance

- Strategie & Planung
- Risk & Business Cont. Mgmt
- Security Management
- Prozess Management
- IT Controlling

Kunde

IT Partnerbetreuung

- IT Marketing
- Service Level Management

IT Innovation

- Release Management
- Projekt Management
- Spezifikation
- Implement-ierung
- Testing

IT Betrieb

- Capacity Management
- Availability Management
- System Management
- Incident Management
- Information Management
- Problem Management
- Change Management

Kunde

IT Infrastruktur / IT Architektur

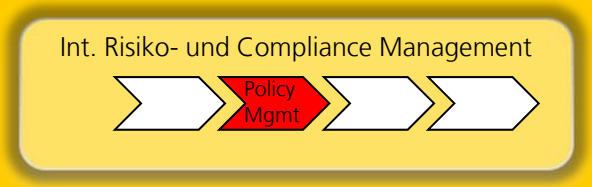
- Architektur Management
- Infrastruktur Management
- Konfiguration Management
- System-bereitstellung

CObIT

ISO27001/2 | ITIL V3 | ISO20000

Risk und Policy Management (3/4)

Welche Vorgaben wirken auf was (Quartiere)?



Insight & Steering

DWH

Verkauf und Beziehungspflege

Personen, Kunden, Verträge

Onlinekanal

Kundenschnittstellen

Financial Services

Interbank

Zahlungs-verkehr

Compliance

Card Issuing & Accuiring

Verarbeitung

Belegerfassung

Output Management

Archiv

Ext. Schnittstellen

Finance & Risk Management

RW

RW & MIS

Tresorerie

Entwicklungs- und Betriebs-Support

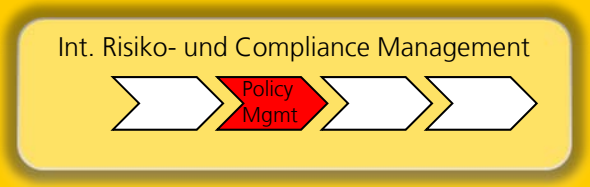
Integration

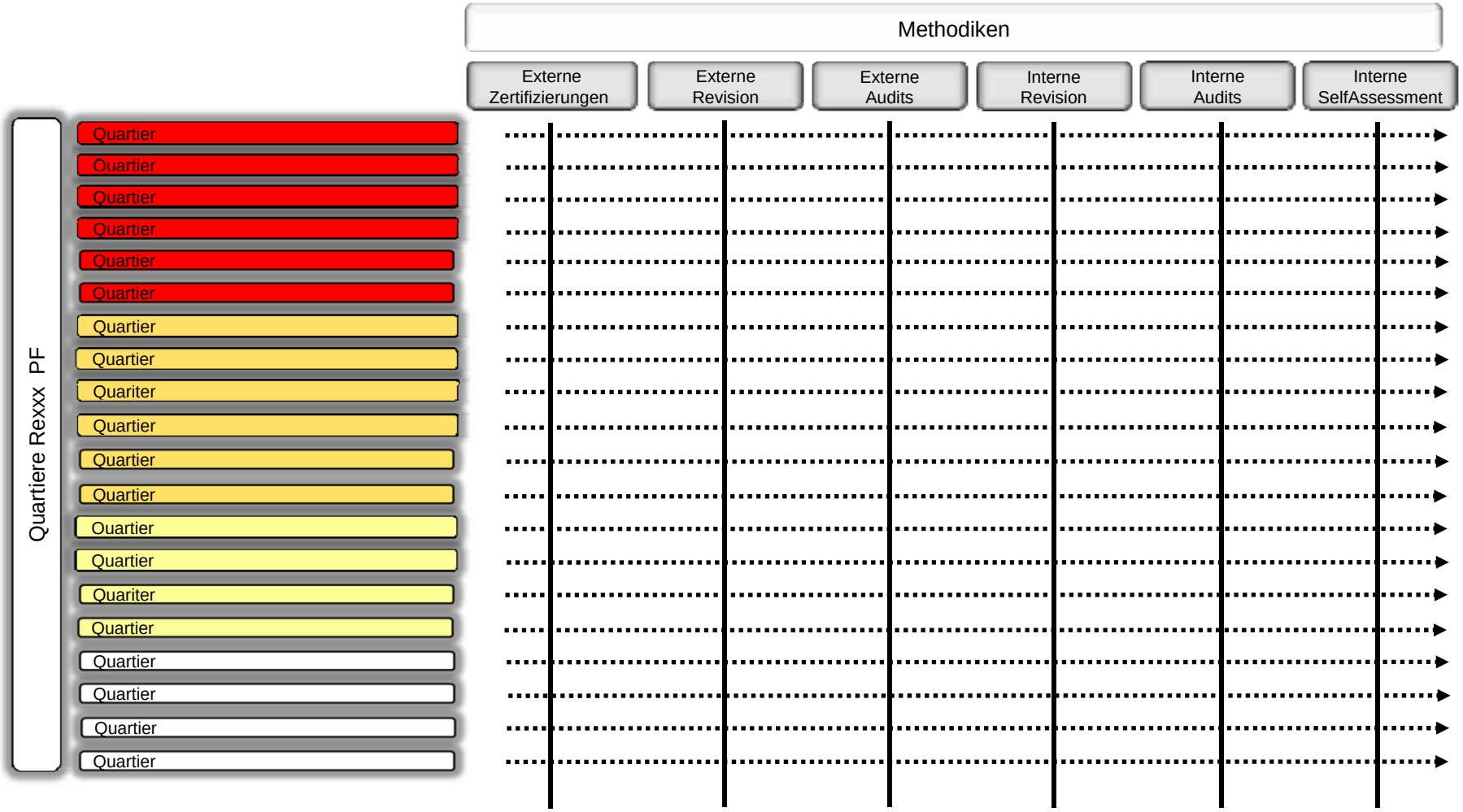
Support

Autorisierungsverwaltung

Risk und Policy Management (4/4)

Wie und wo setzen wir welche Methodiken ein?



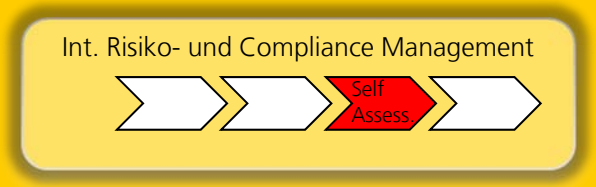


Agenda

- Einleitung
- Ausgangslage
- Lösungsansatz
  - Compliance Strategie / Cartography
  - Risk und Policy Management
  - Risk Control Self Assessment
  - Key Risk Monitoring
- Fragen / Diskussion

Risk Control Self Assessment (1/6)

Open Source – somap.org



Home | Assessment wechseln | Abmelden

ISC - Information Security Compliance

Umsetzungsgradanalyse 2008 (1/2)

HOME | UMSETZUNGSGRADERHEBUNG | FAQ

Über ISC

Passwort ändern

Abmelden

Welcome

Hilfsmittel

Im Benutzerhandbuch sind die wichtigsten Schritte zur Durchführung der Umsetzu
ISC Tool beschrieben.

Benutzerhandbuch

HOME | UMSETZUNGSGRADERHEBUNG | FAQ

Asset

Einträge 1 bis 5 von 13<< < 1 2 3 > >>

Name
Archivierung
Compliance
ISC
PM-Riskmgmt
PM-SLA

DETAIL | VORGABEN

Einträge 1 bis 5 von 46 << < 1 2 3 4 5 6 7 8 9 10 > >

Katalog	Kapitel	Vorgabe	Beschreibung
SiRa PF	10.1.3	title	Die Zuständigkeit/Verantwortung für betriebliche Funktionen muss eindeutig geregelt sein.
SiRa PF	10.10.2	Überwachen von manuellen Eingriffen	Manuelle Eingriffe in das System, wie Softwareänderungen oder Änderungen Systemparameter, müssen aufgezeichnet und überwacht werden.
SiRa PF	10.10.2	Bezeichnung der Aufzeichnungen	Die Dokumentationen sind eindeutig zu bezeichnen und zu datieren. Es is eine Versionisierung der Dokumente vorzunehmen.
SiRa PF	10.10.2	Dokumentation der Ergebnisse betreffend Security Monitoring	Abläufe und Verfahren im Zusammenhang mit dem Security Monitoring sind zu dokumentieren und abzulegen.

HOME | UMSETZUNGSGRADERHEBUNG | FAQ

ISC

Einträge 1 bis 10 von 42 << < 1 2 3 4 5 > >>

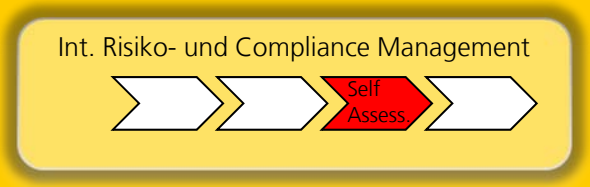
Katalog	Kapitel	Kontrollfrage	Umsetzungsgrad
GSHB Post	10.10.1	Are audit logs recording user activities, exceptions, and information security events produced and kept for an agreed period to assist in future investigations and access control monitoring?	umgesetzt
GSHB Post	10.10.2	Have procedures for monitoring use of information-processing facilities been established, and are the results of the monitoring activities reviewed regularly?	teilweise umgesetz
GSHB Post	10.10.3	Are logging facilities and log information protected against tampering and unauthorized access?	teilweise umgesetz
GSHB Post	10.10.4	Are system administrator and system operator activities logged?	umgesetzt
GSHB Post	10.10.5		
GSHB Post	10.4.2		
GSHB Post	10.9.1		

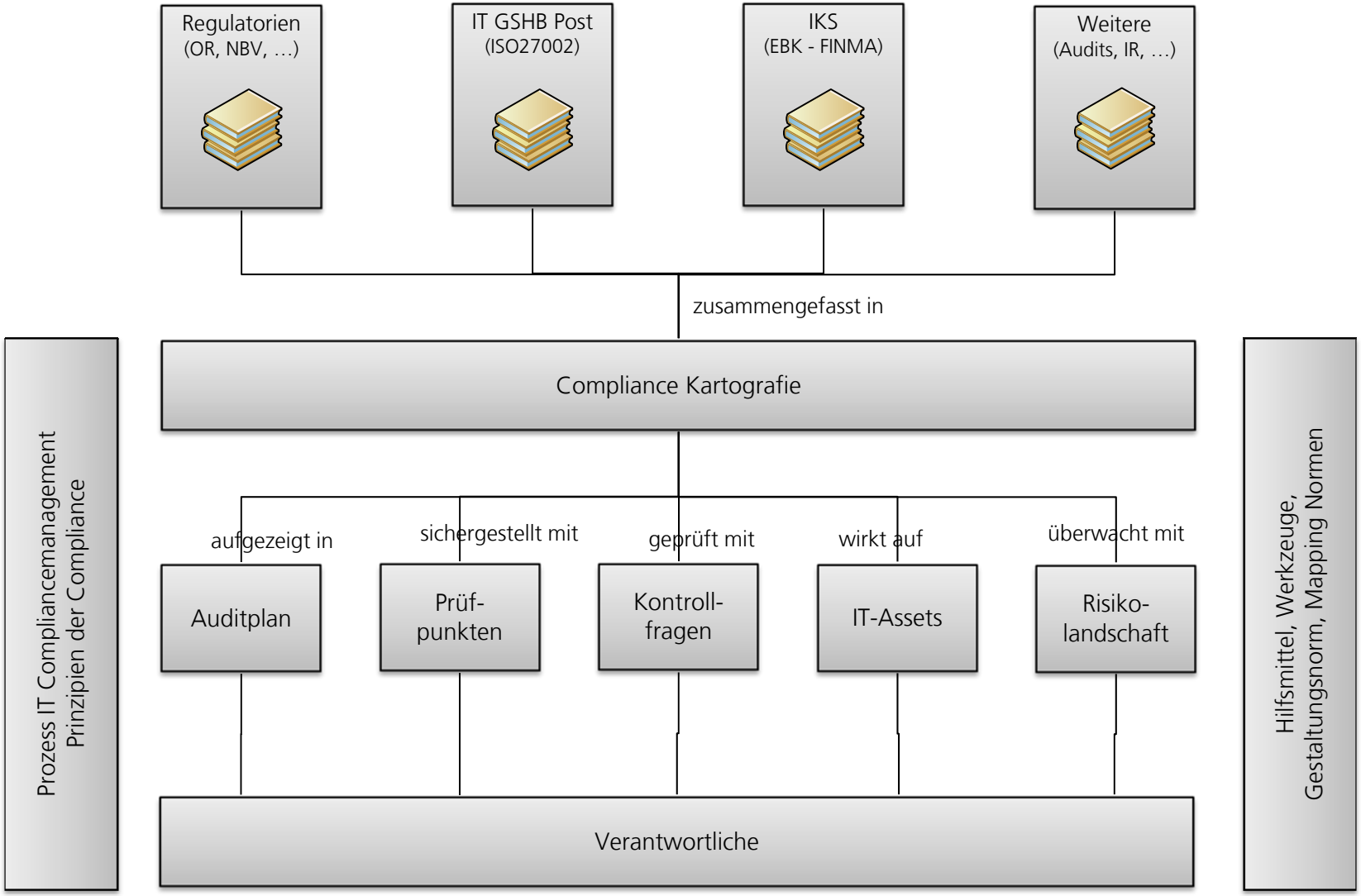
ISC

Katalog *	GSHB Post
Kapitel	10.10.1
Vorgabe	Es müssen Auditprotokolle erstellt werden, in denen Benutzeraktivitäten, Fehler und Informationssicherheitsvorfälle festgehalten werden. Sie müssen für einen vereinbarten Zeitraum verwahrt werden, um in zukünftigen Untersuchungen und Überwachungen der Zugriffskontrolle behilflich zu sein.
Kontrollfrage *	Are audit logs recording user activities, exceptions, and information security events produced and kept for an agreed period to assist in future investigations and access control monitoring?
Kommentar	
Umsetzungsgrad *	umgesetzt

Risk Control Self Assessment (2/6)

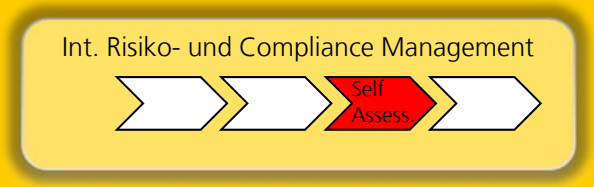
Modell





Risk Control Self Assessment (3/6)

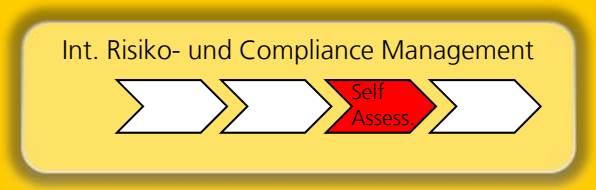
Erhebung Umsetzungsgrad – Impressionen

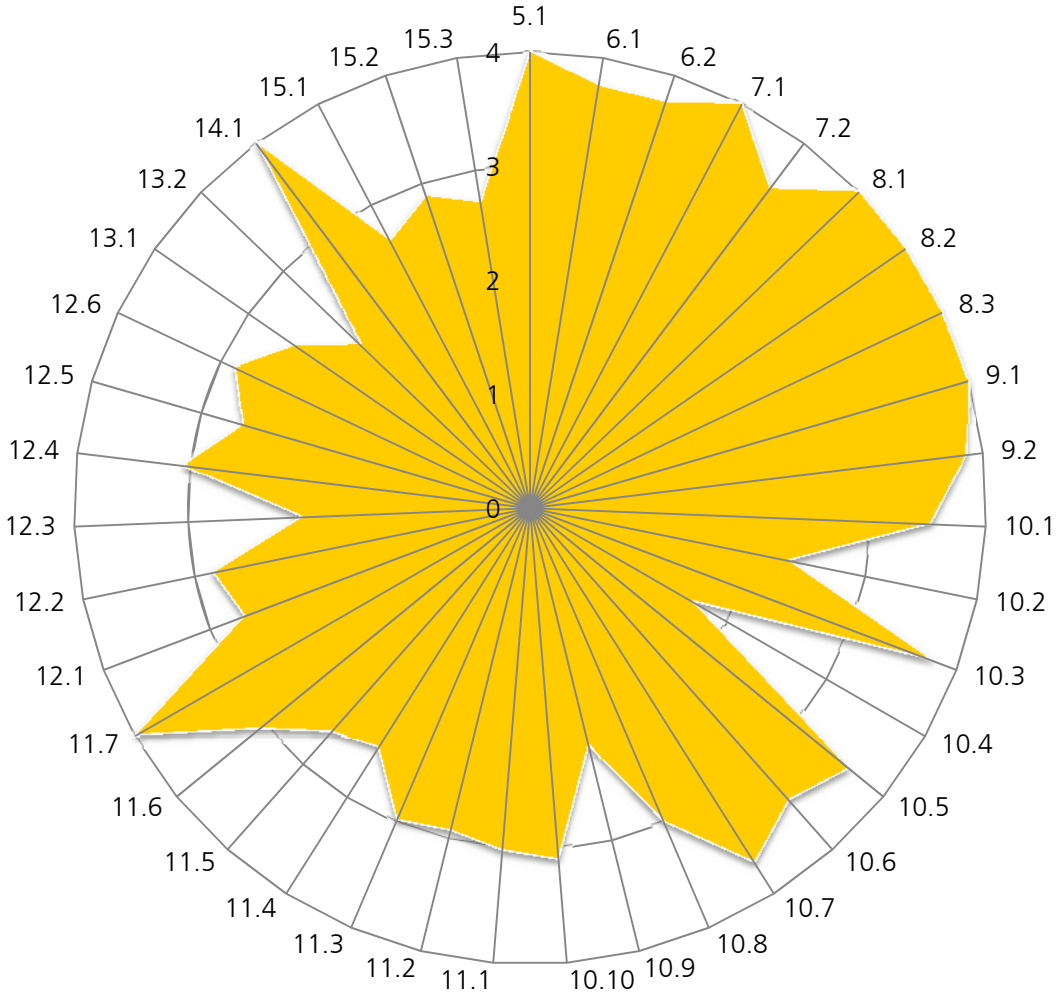


Zeitaufwand für
Schutzobjektverantwortlicher: 2h

Risk Control Self Assessment (4/6)

Ergebnisse Phase1: Gesamtsicht





Legende Skala

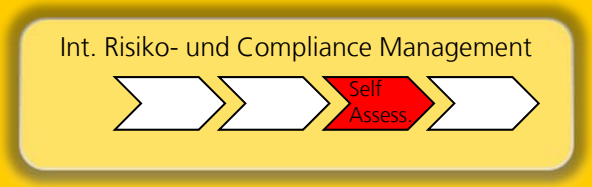
0 -
1 -
2 -
3 -
4 -

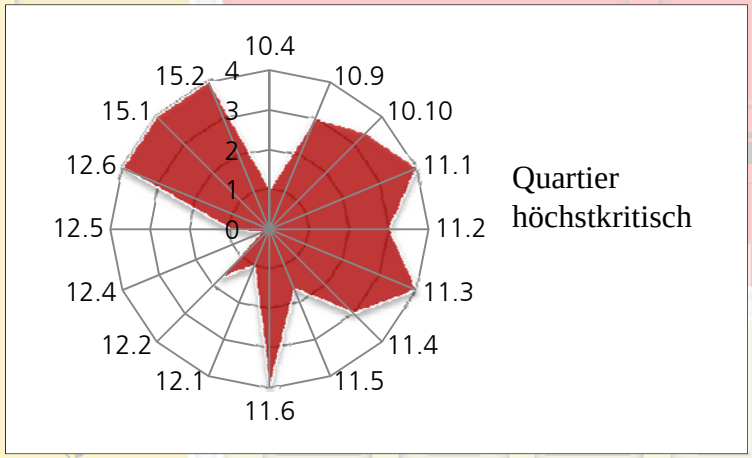
Inhaltsverzeichnis ISO

5. Sicherheitsleitlinie
6. Organisation der Informationssicherheit
7. Management von Informationseigenen Werten
8. Personalsicherheit
9. Physische und Umgebungs-bezogene Sicherheit
10. Betriebs- und Kom-munikationsmanagement
11. Zugangskontrolle
12. Beschaffung, Entwicklung und Wartung von Informationssystemen
13. Umgang mit Sicherheits-vorfällen
14. Sicherstellung des Geschäfts-betriebs
15. Einhaltung von Vorgaben

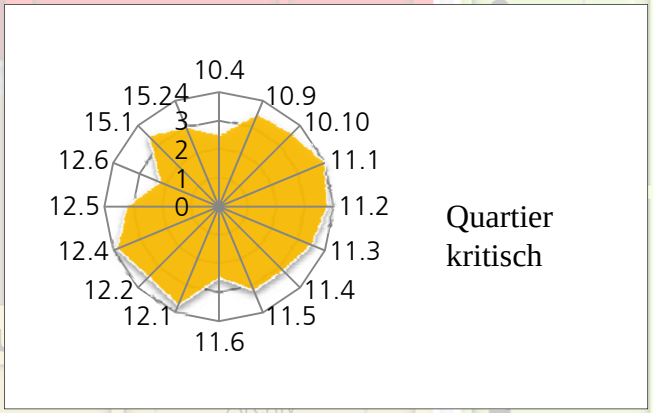
Risk Control Self Assessment (5/6)

Welche Vorgaben wirken auf was (Quartier)?

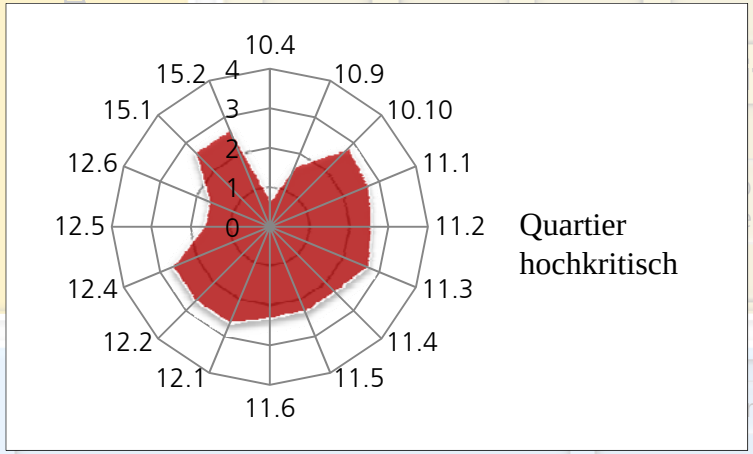




Quartier höchstkritisch



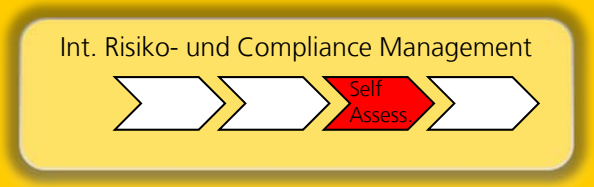
Quartier kritisch



Quartier hochkritisch

Risk Control Self Assessment (6/6)

nächste Schritte



- Erstellen einer Planung in der Linie
  - Die IT-Sicherheit präsentiert an den FM's der Linien die OE spezifischen Schwachstellen
  - Eine Koordinationsstelle innerhalb der OE übernimmt den Lead zur Erarbeitung der Planung (Massnahmen, Kosten, Termine)
  - Zur Erstellung der Planung arbeitet die Koordinationsstelle eng mit den Schutzobjektverantwortlichen und IT-Architekten zusammen.
  - IT-Sicherheit unterstützt die Koordinationsstelle bei Bedarf.

- Die Resultate werden von der IT-Sicherheit konsolidiert. Es werden der IT-Führung anschliessend Massnahmen und Varianten aufgezeigt, die zum erreichen der angestrebten branchenkonformen Sicherheit beitragen.
- Die Reduktion der Schwachstellen wird innerhalb der zuständigen Linie geplant und umgesetzt
- Die nächste IT-GSHB Umsetzungsgraderhebung im 2010 ist für alle Schutzobjekte durchzuführen

Agenda

- Einleitung
- Ausgangslage
- Lösungsansatz
  - Compliance Strategie / Cartography
  - Risk und Policy Management
  - Risk Control Self Assessment
  - Key Risk Monitoring
- Fragen / Diskussion

Key Risk Monitoring

Risk Management und Key Risk Indikatoren

Hauptmenü

Erfassen

- Quell-Ergebnisse erfassen
- Empfehlung erfassen

Erfassen von Ergebnissen zu einzelnen Audits oder Empfehlungen

Report

Schutzobjekt

Quartier

Marktangebot

Übersicht Grob | Übersicht Detail | Liste Prüfpunkte

Das Tool stellt verschiedene Reports zur Verfügung
Zum einen detaillierte Ansichten sortiert nach

- Schutzobjekt
- Quartier
- Marktangebot

Oder Übersichtsreports in unterschiedlicher Granularität

Export

- Auswertung sortiert nach AV
- Auswertung sortiert nach Quartier
- Auswertung sortiert nach Marktangebot

Die Ergebnisse lassen sich in ein Excel exportieren

Kontrollberichte

- Informationen zu IT Schutzobjekten
- Applikationen nach Quartier
- Applikationen nach Markangebot

Hier können verschiedene Berichte für Plausibilitäts-prüfungen geöffnet werden

Key Risk Monitoring

Risk Management und Key Risk Indikatoren

Risikolandkarte PF5

PostFinance
DIE POST

Informationsquelle: Projektassessments

- Ergebnisse (neutraler Topf)
- Ext. Audits
- Ext. Revision
- IKS-DEA - (Design effectivnes Assessment)
- IKS-DET - (Desgin effectivnes Testing)
- Int. Audits (PF5)
- Int. Revision
- IT RAS Zugriffe
- IT Risk Konzern
- IT Security Exception Mgmt
- IT Security Scans
- Kennzahlen (z.B. KPI, KGI)
- Management Assessment
- Projektassessments
- USG Sicherheitsrahmen PF (IT_SiRa PF)

IT-Schutzobjek				um
P2243 - Scale				1.2009
P2243 - Scale				1.2009
P2243 - Scale				1.2009
P2243 - Scale				1.2009
P2243 - Scale				1.2009
P2243 - Scale				1.2009
P2243 - Scale				1.2009
P2243 - Scale				1.2009
P2243 - Scale	PK 3		schlechtes Projektimage	25.11.2009
P2243 - Scale	PK 3		Tabuthemen werden nicht kommun	25.11.2009
				09.12.2009

Record: 1 of 10 No Filter Search

Key Risk Monitoring

Risk Management und Key Risk Indikatoren

Risikolandkarte PF5 - nach Schutzobjekt

IT-Schutzobjekt / Kategorie	Quelle / Prüfpunkt	Indikator
Applikation		
	Int. Revision	
	Steuerungs- und Kontrollumfeld	
	IT Risk Konzern	
	K_IT-Verfügbarkeit	
	USG Sicherheitsrahmen PF (IT_SiRa PF)	
	Kontrolle technischer Schwachstellen	
	Isolation sensitiver Systeme	
	Kontrolle der internen Verarbeitung	
	Benutzerregistrierung	
	Analyse und Spezifikation von Sicherheitsanforderungen	
	Zugangskontrolle zu Quellcode	
	Verwalten von Passwörter	
	Schutz der Diagnose- und Konfigurationsports	
	Inhalt der Dokumentation	
	Schutz von Protokollinformationen	
	Schutz vor mobiler Software (mobilen Agenten)	
	Ausgelagerte Softwareentwicklung	
	Überprüfung von Ausgabedaten	
	Administrator- und Betreiberprotokolle	
	Überprüfung von Benutzerberechtigungen	
	Passwortverwendung	
	Online Transaktionen	

Agenda

- Einleitung
- Ausgangslage
- Lösungsansatz
  - Compliance Strategie / Cartography
  - Risk und Policy Management
  - Risk Control Self Assessment
  - Key Risk Monitoring
- Fragen / Diskussion

Vielen Dank für Ihre Aufmerksamkeit.

Sicherheit für alle.

Markus Siffert
Sicherheitsbeauftragter Informatik

Die Schweizerische Post
PostFinance
Informatik Sicherheit
Engehaldenstrasse 37
CH-3030 Bern

Internet: www.somap.org
E-Mail: switzerland-chapter@somap.org